

# OAuth 2.0 API Testing Lab

Keycloak • FastAPI • Postman • Rest Assured — full run report, generated 2026-09-13

8 / 8 tests passed

mvn test exit code 0

Realm: api-testing

Keycloak 26.7.3

## 1 Environment Setup

| TOOL                       | INITIAL STATE     | ACTION TAKEN                                                                        |
|----------------------------|-------------------|-------------------------------------------------------------------------------------|
| Python 3.13.3              | Already installed | None                                                                                |
| Java 17 (Homebrew OpenJDK) | Already installed | None                                                                                |
| Docker                     | Missing           | <code>brew install --cask docker</code> , launched with <code>open -a Docker</code> |
| Maven 3.9.16               | Missing           | <code>brew install maven</code>                                                     |

## 2 Keycloak Configuration

Container: `keycloak` (image `quay.io/keycloak/keycloak:26.7.3` )

Port: `127.0.0.1:8080`

Admin login: `admin / admin`

Realm: `api-testing` (created via Admin REST API)

Client 1: `api-automation-client`

Confidential, service account on, role `api-user` assigned

Access-token lifespan overridden to `6s` (expiry test)

Client 2: `api-automation-client-norole`

Confidential, service account on, **no role** (403 test)

Client secrets are generated by Keycloak and only ever held as shell env vars ( `CLIENT_ID` , `CLIENT_SECRET` , `CLIENT_ID_NOROLE` , `CLIENT_SECRET_NOROLE` ) — never written to disk or logged in full.

## 3 Files Created / Modified

| FILE                                         | PURPOSE                                                                                                                                                                      |
|----------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| api/requirements.txt                         | fastapi, uvicorn, pyjwt[crypto]                                                                                                                                              |
| api/app.py                                   | FastAPI /users endpoint with real JWT validation: signature via Keycloak JWKS ( PyJWKClient ), issuer check, audience check, expiry check, realm-role check (403 if missing) |
| rest-assured/pom.xml                         | rest-assured 5.5.6, junit-jupiter 5.13.4, maven-surefire-plugin 3.2.5                                                                                                        |
| rest-assured/src/test/java/0AuthApiTest.java | 8 JUnit 5 tests covering the full scenario matrix                                                                                                                            |

#### 4 Test Results ● ALL PASS

| # | TEST                                            | SCENARIO                          | VERIFIED RESULT                              |
|---|-------------------------------------------------|-----------------------------------|----------------------------------------------|
| 1 | apiWithoutToken_returns401                      | No Authorization header           | <b>401</b> — Missing Authorization header    |
| 2 | apiWithMalformedToken_returns401                | Garbage bearer token              | <b>401</b> — Malformed token                 |
| 3 | apiWithValidToken_returns200                    | Valid token, has role             | <b>200</b> — Authenticated successfully      |
| 4 | apiWithInsufficientRole_returns403              | Valid token, missing role         | <b>403</b> — Missing required role: api-user |
| 5 | apiWithExpiredToken_returns401                  | Token used after 8s (lifespan 6s) | <b>401</b> — Token expired                   |
| 6 | tokenRequestWithWrongClientSecret_returns401    | Correct client_id, wrong secret   | <b>401</b> — unauthorized_client             |
| 7 | tokenRequestWithInvalidClientId_returns401      | Nonexistent client_id             | <b>401</b> — invalid_client                  |
| 8 | tokenRequestWithUnsupportedGrantType_returns400 | Bogus grant_type                  | <b>400</b> — unsupported_grant_type          |

```
$ mvn -q test
exit_code=0    # all 8 tests passed
```

## 5 README Step Coverage (1–19)

- ✓ Steps 1–5 — Keycloak realm, client, secret, service account (done via Admin REST API)
- ✓ Steps 6–7 — FastAPI project created and started on `:8000`
- ✓ Steps 8–10 — 401 without token, token fetched, 200 with token (verified live)
- ✓ Step 11 — Credentials via env vars only, never hardcoded
- ✓ Step 12 — Rest Assured project builds and compiles clean
- ✓ Step 13 — All key test-scenario table rows implemented and passing
- ✓ Step 14 — 401 vs 403 demonstrated by tests 1–4
- ✓ Steps 15–18 — Reference/explanation sections, no code required
- ✓ Step 19 — Advanced exercise: real JWT validation (signature, issuer, audience, expiry, `app.py` role) implemented in

## 6 How to Reproduce

```
docker start keycloak
cd api && uvicorn app:app --port 8000

# in the same shell, export before testing:
export CLIENT_ID=api-automation-client
export CLIENT_SECRET=<from Keycloak Credentials tab>
export CLIENT_ID_NOROLE=api-automation-client-norole
export CLIENT_SECRET_NOROLE=<from Keycloak Credentials tab>
```

```
cd rest-assured && mvn test
```

Generated automatically as part of the OAuth API Testing Lab automation session · repo facts and gotchas also saved to `/memories/repo/oauth-lab-setup.md` for future runs.